

O documento original está disponível na Rede Interna da ONDACOM		
Elaboração do documento: Sofya Kewry Rodrigues	Análise Crítica e revisão: Marcos De Jesus Pereira	Aprovação: Marcos De Jesus Pereira
Este documento quando impresso só é válido para uso se possuir carimbo de Cópia Controlada		

1. OBJETIVO

Esta política tem como objetivo estabelecer as diretrizes e os critérios de segurança da informação para Ondacom Serviços de Telecomunicação, com base nas melhores práticas internacionais, incluindo as normas da série ISO/IEC 27000, que abordam a gestão da segurança da informação. O objetivo é garantir a confidencialidade, integridade e disponibilidade dos dados e sistemas da empresa, protegendo-os contra riscos como acessos não autorizados, uso inadequado, perdas e danos.

2. ABRANGÊNCIA

A política de segurança da informação se aplica a todos os colaboradores, prestadores de serviços, fornecedores e parceiros da Ondacom Serviços de Telecomunicação que têm acesso aos sistemas e dados da empresa. O escopo inclui:

- Infraestrutura de TI (servidores, redes, sistemas).
- Dados e informações, tanto pessoais quanto corporativas.
- Processos internos e externos que envolvem o tratamento de informações.
- Plataformas de comunicação e colaboração.
- Aplicações e serviços terceirizados.

3. GOVERNANÇA DA SEGURANÇA DA INFORMAÇÃO

A governança de segurança da informação será conduzida por um conjunto de funções, estruturas e responsabilidades para assegurar que a segurança esteja alinhada com os objetivos estratégicos da empresa e com as melhores práticas de

	Política de Segurança da Informação	PG-069 R00
		Página 2 de 6

mercado. A **Ondacom Serviços de Telecomunicação** segue as diretrizes da ISO/IEC 27001 e da ISO/IEC 27002, que definem requisitos para um Sistema de Gestão de Segurança da Informação (SGSI) eficaz.

- **Comitê de Governança de Segurança da Informação:** Responsável pela supervisão geral da segurança da informação na organização. Este comitê é composto por membros da alta gestão, incluindo o CEO, CIO, DPO (Encarregado de Proteção de Dados) e o CSO (Chief Security Officer). O comitê toma decisões estratégicas sobre as políticas e normas de segurança, assegurando que os recursos adequados sejam alocados para a proteção da informação.
- **Gestor de Segurança da Informação (CISO):** Responsável pela implementação e monitoramento do SGSI. O CISO tem a função de desenvolver, revisar e ajustar políticas, normas e procedimentos de segurança, além de coordenar os treinamentos e campanhas de conscientização sobre segurança da informação. Ele também gerencia incidentes de segurança, avaliando riscos e aplicando controles para mitigar ameaças.
- **Encarregado de Proteção de Dados (DPO):** Responsável pela proteção dos dados pessoais e pelo cumprimento das normativas de privacidade e proteção de dados (como a LGPD no Brasil). O DPO trabalha de forma colaborativa com o CISO para garantir que as práticas de segurança estejam em conformidade com as regulamentações de proteção de dados.
- **Equipe Técnica de Segurança (TI e Segurança):** Responsável pela implementação e manutenção dos controles técnicos de segurança, como firewalls, antivírus, criptografia, monitoramento de redes, backup e recuperação de dados, além de garantir que a infraestrutura de TI esteja segura contra ameaças.

4. ESTRUTURA E FUNÇÕES DA SEGURANÇA DA INFORMAÇÃO

A estrutura de governança da segurança da informação é baseada nas seguintes funções:

4.1. PLANEJAMENTO DE SEGURANÇA

- Definir e implementar políticas, normas e procedimentos de segurança com base nas melhores práticas de mercado e nas normas ISO/IEC 27000.
- Identificar e avaliar os riscos de segurança, com base nas ameaças e vulnerabilidades dos sistemas de informação.
- Estabelecer controles para mitigar os riscos identificados, priorizando as áreas mais críticas.

4.2. CONTROLE DE ACESSO

- Implementar controles de acesso baseados em "privilégios mínimos", garantindo que os funcionários e terceiros tenham acesso apenas às informações necessárias para o desempenho de suas funções.
- Definir políticas claras de autenticação, incluindo o uso de senhas fortes, autenticação multifatorial (MFA) e monitoramento contínuo de acessos.

4.3. GESTÃO DE INCIDENTES DE SEGURANÇA

- Estabelecer processos claros para a identificação, resposta e resolução de incidentes de segurança, como ataques cibernéticos, vazamento de dados ou falhas de sistema.
- Criar um plano de resposta a incidentes que inclua a comunicação imediata com as partes afetadas, auditorias forenses e ações corretivas.

4.4. PROTEÇÃO DE DADOS PESSOAIS

- Implementar medidas específicas para a proteção de dados pessoais e sensíveis, garantindo conformidade com legislações como a LGPD.
- Estabelecer práticas de anonimização, criptografia e controle de acesso rigoroso para garantir a privacidade dos dados.

4.5. TREINAMENTO E CONSCIENTIZAÇÃO

- Realizar treinamentos periódicos para os colaboradores sobre as políticas de segurança da informação, riscos cibernéticos e boas práticas de segurança.
- Desenvolver campanhas de conscientização contínuas sobre phishing, segurança de senhas e prevenção contra malware.

4.6. MONITORAMENTO E AUDITORIA

	Política de Segurança da Informação	PG-069 R00
		Página 4 de 6

- Implementar sistemas de monitoramento contínuo para detectar e responder rapidamente a incidentes de segurança, utilizando ferramentas de SIEM (Security Information and Event Management).
- Realizar auditorias internas e externas para avaliar a eficácia das políticas de segurança e identificar pontos de melhoria.

4.7. SEGURANÇA FÍSICA

- Garantir a segurança física dos recursos de TI, incluindo servidores e datacenters, por meio de controle de acesso físico, vigilância, sistemas de alarme e restrição de acesso a áreas sensíveis.

5. POLÍTICAS E NORMAS DE SEGURANÇA

A Ondacom Serviços de Telecomunicação segue uma série de políticas, normas e procedimentos internos que regulam o tratamento e a proteção das informações. Essas normas são baseadas nas melhores práticas da ISO/IEC 27000, incluindo as seguintes:

5.1. POLÍTICA DE CONTROLE DE ACESSO

- Definir regras para a criação, modificação e remoção de contas de usuário.
- Garantir que os acessos sejam revogados prontamente em caso de desligamento ou mudança de função do colaborador.

5.2. POLÍTICA DE USO ACEITÁVEL

- Estabelecer as diretrizes para o uso adequado dos recursos tecnológicos da empresa, como e-mails, internet e dispositivos móveis.
- Proibir práticas que possam comprometer a segurança, como o uso de softwares não autorizados ou a instalação de dispositivos externos sem verificação.

5.3. POLÍTICA DE PROTEÇÃO DE DADOS

- Garantir que os dados pessoais sejam armazenados de forma segura, criptografados quando necessário, e que sejam acessados somente por pessoas autorizadas.

	Política de Segurança da Informação	PG-069 R00
		Página 5 de 6

- Estabelecer normas para a destruição de dados pessoais ou sensíveis quando não forem mais necessários.

5.4. POLÍTICA DE BACKUP E RECUPERAÇÃO DE DADOS

- Implementar rotinas de backup regulares, garantindo que os dados críticos sejam mantidos e possam ser recuperados em caso de perda ou falha de sistema.

5.5. POLÍTICA DE SEGURANÇA EM SISTEMAS E APLICAÇÕES

- Garantir que todos os sistemas e aplicações da empresa passem por processos de análise de segurança, como testes de vulnerabilidade e correção de falhas.
- Adotar práticas de segurança no desenvolvimento de software, incluindo a implementação de testes de segurança durante o ciclo de vida do desenvolvimento.

6. CONFORMIDADE COM NORMAS INTERNACIONAIS (ISO/IEC 27000)

A **Ondacom Serviços de Telecomunicação** adota as seguintes normas da ISO/IEC 27000 para garantir a robustez do sistema de segurança da informação:

- **ISO/IEC 27001:** Define os requisitos para a implementação e manutenção de um Sistema de Gestão de Segurança da Informação (SGSI), com foco na gestão de riscos e implementação de controles de segurança.
- **ISO/IEC 27002:** Fornece um código de boas práticas para controles de segurança, que incluem tópicos como controle de acesso, segurança física, gestão de incidentes e continuidade de negócios.
- **ISO/IEC 27005:** Oferece diretrizes sobre a gestão de riscos em segurança da informação, com foco na identificação, avaliação e tratamento de riscos.

A empresa realiza auditorias periódicas para garantir a conformidade com estas normas e para identificar áreas que necessitam de melhorias.

8. AUDITORIAS E MONITORAMENTO

A **Ondacom Serviços de Telecomunicação** implementará auditorias regulares para avaliar a conformidade com esta política e a eficácia dos controles de segurança. O monitoramento contínuo será feito por ferramentas especializadas para detectar e responder a incidentes de segurança em tempo real.

ELABORAÇÃO:

Sofya Kewry Rodrigues

APROVAÇÃO (Diretoria da área):

Nome(s) e cargo(s) do(s) responsável(is)

APROVAÇÃO (Conselho Administrativo):

Marcos De Jesus Pereira